

EGAS

Promotion & Secondment Workflow System

Final Requirements & System Architecture Baseline

Version 3.0 - FINAL Implementation Baseline

16 August 2026

Item	Authoritative value
Status	Clean consolidated baseline after verified Phase 2A and CAP-to-Express architecture migration
Supersedes	EGAS Requirements & Architecture Baseline v2.0 where this v3.0 document differs; preserves all non-conflicting business/workflow/security requirements
Frontend baseline	React + TypeScript; Arabic-first RTL; no SAP UI5/Fiori runtime dependency
Backend baseline	Node.js + TypeScript + Express 5 modular monolith; REST/JSON
Database baseline	PostgreSQL accessed through pg/node-postgres; versioned SQL migrations are implementation schema authority
Data integration	Controlled annual approved Excel snapshot import; no direct SAP HCM/database integration
Deployment	Standalone internal EGAS network web application
Security target	Backend-enforced authorization; OWASP ASVS 5.0 Level 2 engineering target

Active SAP association policy

SAP/Fiori/HCM remain only in historical BRD traceability. They are not runtime technologies, deployment requirements, UI dependencies, database dependencies, or integration dependencies in this baseline.

1. Document control, precedence and architecture freeze

1.1 Revision control

Version	Date	Status	Description
2.0	15 Aug 2026	Final baseline	Requirements-analysis freeze with CAP/UI5 implementation architecture and final workflow/signoff/data corrections.
3.0	16 Aug 2026	FINAL implementation baseline	Consolidates v2.0 business requirements and verified security decisions; replaces active CAP/CDS/CQN/UI5/Fiori architecture with React + Express + pg + PostgreSQL after successful parity migration.

1.2 Authoritative precedence

Where artifacts conflict, use the following order:

Priority	Artifact / source	Rule
1	This v3.0 Final Requirements & Architecture Baseline	Business rules, workflows, security, active technical architecture, acceptance and source precedence.
2	Current versioned PostgreSQL SQL migrations and verified physical schema under services/api	Implementation schema authority. Applied migration history/checksums must not be rewritten.
3	EGAS_UI_CONTEXT_v1.4_Final.md and approved screen handoffs	Business/interaction intent remains valid. Any CAP/UI5/Fiori implementation wording is superseded by v3.0.
4	DESIGN.md / approved Stitch visual assets	Visual hierarchy, Arabic RTL design intent and component behavior only; no SAP runtime dependency.
5	AGENTS.md + versioned Codex handoff prompts	Repository guardrails and task sequencing; cannot override higher-priority business/security requirements.

1.3 Architecture decision now frozen

```

React + TypeScript
  |
  | HTTPS / REST / JSON
  v
Node.js + TypeScript + Express 5
  |
  | pg / parameterized SQL
  v
PostgreSQL

```

Annual approved XLSX -> controlled staging/validation/activation -> PostgreSQL annual snapshot

Normal browser operation has no direct database connection and no SAP runtime path. The application is deployed independently on the EGAS internal network.

1.4 Verified implementation checkpoint

Checkpoint	State at v3.0 freeze
Phase 1 database/foundation	Complete and preserved. Runtime database role is egas_app; 22/22 routing units active; privileged bootstrap Admin intact.
Phase 2A authentication/Admin	Complete: Argon2id, opaque server-side sessions, CSRF/Origin controls, mandatory password change, single active role, Admin/authority/delegation APIs, security events.
CAP -> Express migration	Complete and locally verified. services/cap-api removed; @sap/cds and @cap-js dependencies absent; Express service starts independently.
Quality gates	Build, typecheck, security check and dependency audit passed; migrated test suite passed 31/31 tests at freeze.
Historical CAP DB artifacts	cds_model and cds_outbox_messages retained only as historical tables; egas_app has no access.
Pilot readiness	Authority coverage 0/22 and active annual snapshot absent; these remain deliberate pre-pilot/data setup gates, not architecture failures.

2. Final decisions carried forward from v2.0

Open item	Final decision / correction	Implementation effect
Missing employee الإدارة / التبعية التنظيمية	The authoritative annual eligible workbook does not provide these employee-level fields. The system shall not infer them from النيابة . Proposed secondment organizational dependency remains a manual Organization field.	No fabricated employee field; keep manual secondment dependency input.
"10" sentinel	The current workbook uses blanks. Normalize blank/whitespace to NULL. Also accept literal trimmed "10" as NULL only for backward compatibility if encountered.	Importer handles the real dataset and remains tolerant.
Unmapped routing labels	Unknown source routing labels are blocked per employee until explicitly mapped to an approved routing unit or a new unit is formally approved. No fuzzy/automatic guessing.	Routing-unit source-alias mapping; affected rows cannot enter workflow until resolved.
Authority workbook	Reference-only. It must not auto-create accounts, roles or authority assignments.	Operational accounts and authority mappings remain manual Admin configuration.
Excel schema validation	Validate required header names before staging. Match by header name, not fixed column position.	Wrong workbook/missing/duplicate headers are rejected early.
SAP/Fiori BRD mismatch	IT consultation supersedes direct SAP HCM integration and SAP-Fiori-platform hosting. Annual approved Excel snapshot + standalone internal web application are the final baseline.	Keep historical traceability only; no SAP runtime or UI dependency.
Visible signoff stage	EA visible block = P1/S1 initial signoff; Organization visible block = P2/S2 initial signoff, from the final completed iteration.	Later approvals do not replace official-form signer blocks.
View as PDF - every workflow actor	Every operational actor can open an immutable official-form PDF snapshot of exactly the data received at the task/stage; later-owned fields remain blank.	Received-stage PDFs never change after later edits; draft/final actions are separate.
Per-candidate notes	Any workflow actor can append notes/messages. Every candidate-level note appears chronologically in the official ملاحظات column; request-level notes remain workflow messages/history.	Append-only workflow_note model and audit attribution.
Level-1 eligibility	The supplied annual workbook is already the eligible v1 population.	No second eligibility engine is invented.
Multi-role users	One account may hold multiple roles; exactly one active role controls authorization at a time.	Permissions are never unioned; active role is persisted/audited.

3. Introduction, scope and system context

3.1 Purpose

This baseline defines the functional, workflow, data, security, user-interface, reporting, PDF, deployment and quality requirements for the EGAS Promotion & Secondment Workflow Website, together with the active system architecture used for implementation and testing.

3.2 Product objective

- Digitize the two paper-driven first-level-and-below workflows for Secondment (ندب) and Promotion (ترقية).
- Route forms through Employee Affairs, Organization and the responsible Approving Authority with complete traceability.
- Use an annually supplied approved Excel snapshot imported through a controlled process into PostgreSQL; no direct SAP integration is required or used.
- Produce redesigned Arabic official-form PDFs plus a separate printable audit-log PDF.
- Operate as an internal, Arabic-first application on the EGAS network with local application accounts, role-based access and in-app notifications.

3.3 Definitions

Term	Meaning
Employee Affairs (شئون العاملين)	Creates requests, receives returns, performs promotion intermediate review and final approval.
Organization (إدارة التنظيم)	Claims assigned work, enters/reviews organization-controlled information and proposed secondment positions.
Approving Authority	Configured executive approver for a routing unit; may hold Deputy, Assistant or acting-equivalent job title. Authorization comes from explicit assignment records, not job-title text.
Routing Unit (النيابة / المساعد)	One of the 22 top-level workflow routing values used by forms and assignment rules.
Worksheet / Form	A promotion or secondment request containing one or more employees routed under the same routing unit.
Iteration	One workflow pass. Restart creates a new iteration while preserving prior history.
Annual Snapshot	Approved employee dataset supplied once per cycle and imported into PostgreSQL.
Form Section / Job Category	Controlled subsection used by the printable form, such as مدير إدارة, نمطي ماهر or رئيس قسم, نمطي أول, نمطي ممتاز.

3.4 In scope for v1 product release

- Promotion and Secondment workflows only.
- Local application accounts for Admin, Employee Affairs, Organization and Approving Authority users.
- Separate Admin Portal and Workflow Portal with role-specific screens.
- Controlled annual full-snapshot Excel staging, validation and activation into PostgreSQL.
- Request creation, employee lookup, grouping, stage claiming/assignment, review, approvals, rejection, return, cancellation, recall and restart.
- In-app notifications, immutable/tamper-evident audit history, search/history, operational dashboards and PDF generation.
- Arabic RTL interface on company-approved Chrome, Firefox and Edge for laptop/desktop; WCAG 2.2 AA target.

3.5 Out of scope for v1

- Live SAP HCM integration, direct SAP database access, OData/RFC/BAPI integration, SAP BTP dependency, SAP Fiori hosting or writing results back to SAP.
- SAP UI5 Web Components or other SAP UI runtime libraries.
- Active Directory/SSO authentication in v1; authentication remains replaceable behind a provider boundary.
- Public Internet access, mobile application, employee self-service or employee participation in approvals.
- Automatic vacancy sourcing or automatic job-description eligibility calculation.
- Email notifications; v1 notifications are in-app.
- Production-grade HA/DR beyond the pilot baseline until EGAS IT defines production infrastructure standards.

3.6 Dataset context

The annual eligible employee workbook is the authoritative operational population for the cycle. Other broader staff/authority workbooks are reference material only and shall not create application accounts or infer authority from textual job titles. Real operational staff identifiers are entered manually by Admin and are not embedded in source seeds or this specification.

4. Roles, access model and business rules

4.1 Roles and permissions

Role	Permissions / Scope
Administrator	Separate Admin Portal. Create/edit/deactivate users; reset passwords; assign/revoke roles; manage routing units and approving-authority assignments; create/disable temporary authority delegations; view system-wide audit/search/reports; supervise controlled annual-dataset import status. The first privileged Admin is created by controlled bootstrap; only Admins with Manage Admins may create/manage other Admins. Cannot rewrite audit history.
Employee Affairs	Create promotion/secondment requests, add eligible employees, submit, view status of owned requests, receive returns/rejections/recalls, correct/restart/cancel, perform the promotion intermediate review, and perform final approval.
Organization	See unassigned Organization work; atomically claim a request; other Organization users see who claimed it; enter/review organization-controlled data and secondment vacancy options; submit/approve/return/reject as allowed.
Approving Authority	Configured executive approver for one or more routing units. Sees only requests routed through active authority assignments/delegations available to that account. Makes per-employee decisions and may return/reject with reason. One person may cover multiple units if explicitly configured.
Employee subject	No login and no direct interaction. Appears only as employee data within a request.

4.2 Role-based visibility requirements

ID	Requirement	Source
FR-ACL-01	The backend shall enforce authorization independently of frontend route visibility.	S2 NFR-04
FR-ACL-02	Employee Affairs users shall see and act on requests they created/own, including requests returned to them.	S2 NFR-04
FR-ACL-03	Organization users shall see the Organization queue, unassigned work and requests claimed by themselves; claimed requests shall visibly show the claiming user to other Organization users.	S2 #4
FR-ACL-04	An Approving Authority shall access only requests whose active routing-unit authority assignment (or valid delegation) grants that user scope.	S2 BR-DEP-02
FR-ACL-05	Admin shall have system-wide account, audit and reporting scope but shall not be permitted to edit/delete audit events.	S2 #1, NFR-05
FR-ACL-06	Delegated Approving Authority access shall be scoped to a specific authority assignment/routing unit, explicitly created/disabled by Admin, and fully audited.	S2 BR-DEP-08
FR-ACL-07	Each active routing unit shall have exactly one active primary approving-authority assignment before pilot acceptance. The assigned person may be a Deputy, Assistant, acting Deputy or acting Assistant.	S6; engineering routing baseline

ID	Requirement	Source
FR-ACL-08	The same approving authority may be assigned to more than one routing unit when approved by Admin/HR configuration; the system shall not enforce person-level uniqueness across units.	S6 evidence of combined responsibilities ; engineering correction

4.3 Business rules

ID	Requirement	Source
BR-001	v1 contains exactly two business workflows: Secondment and Promotion.	S2 BR-PO-01
BR-002	Each request/form belongs to exactly one routing unit (النيابة / المساعد) and may contain multiple employees routed under that same unit.	S1 p4; S2 #32,#5
BR-003	There is no business maximum on the number of employees in one form; the UI and PDFs shall handle large forms through paging/page breaks.	S2 #5
BR-004	Employees included in the approved annual Excel snapshot are the eligible population for that cycle.	S2 #2
BR-005	Performance rating or proceeds normally. Rating shall show a زاتم ادج ديح ديح warning to Employee Affairs and Organization but shall not automatically block progress.	S2 BR-ORG-05
BR-006	A missing performance rating shall be displayed as unavailable and shall not be silently converted to a positive eligibility result. Human users retain the decision.	Engineering from S2 #1
BR-007	Secondment vacancy options are manually entered by Organization and are unlimited per employee.	S1 p3; S2 BR- ORG-02,03
BR-008	The Approving Authority decides secondment outcomes one employee at a time because reasons/notes may differ.	S2 BR-DEP-09
BR-009	For promotion, the Approving Authority decides "same position" versus "another position"; choosing another position requires manual entry of the target job title.	S2 BR-ORG-10,11
BR-010	Reject, return-for-correction and cancellation are distinct outcomes. Reject/return must include a reason.	S2 BR-EA-11,BR- DEP-04/05/06
BR-011	Any rejected/returned workflow returns to the originating Employee Affairs user, who decides whether to restart the request or cancel it.	S2 #13,#28,#40,#46
BR-012	Restart creates a new workflow iteration beginning at Employee Affairs while preserving every prior event and decision.	S2 #13,#28,#40
BR-013	Employee Affairs may recall a request at any non-final stage; recall starts a new iteration from the beginning and is audited.	S2 BR-EA-09
BR-014	After final Employee Affairs approval, the request is complete and immutable. It cannot be reopened through the normal application workflow.	S2 BR-EA-12,#7
BR-015	The final form is generated on demand from the frozen approved snapshot; regeneration shall not alter approved data.	S2 NFR-07,#7
BR-016	The audit log is a separate printable PDF and can cover one request or multiple requests in the same department, with period filtering.	S2 #6
BR-017	The 22 values supplied as / are routing units, not a guarantee of 22 النيابة / المساعد distinct people. Each active unit must resolve to one current primary Approving Authority.	S2 #10 + S6

ID	Requirement	Source
BR-018	An Approving Authority may hold a Approving Authority, Assistant or acting- equivalent job title. One person may cover multiple routing units if configured.	S6
BR-019	Request creation shall use controlled drop-downs for routing unit and current approving authority; only active approved authority assignments may be selected.	Stakeholder follow-up 15 Aug 2026
BR-020	The selected routing unit and approving authority identity/title shall be snapshotted with the request so later staffing changes do not rewrite historical approvals.	Engineering/ history requirement
BR-021	Printable-form subsections shall be selected from the approved job-category drop-down: مدير إدارة, رئيس قسم, نمطي أول, نمطي ممتاز, نمطي ماهر. Candidates are grouped under the selected subsection.	S2 #8,#18; S4
BR-022	Secondment vacancy title and organizational dependency are manually entered by Organization; qualification compliance is selected from مستوفي / غير مستوفي. Promotion Other Position requires manual target-job entry by the Approving Authority.	S4; S2 BR- ORG/DEP answers

5. Functional requirements

5.1 Authentication and account management

ID	Requirement	Source
FR-AUTH-01	v1 shall use application-managed local accounts. Active Directory/SSO is out of scope for v1.	S2 #8
FR-AUTH-02	The Admin Portal shall have a separate login route/UI from the operational Workflow Portal.	S2 #11,#69
FR-AUTH-03	Admin shall manually create operational user accounts with staff identifier, display name, username, role and any role-specific configuration. No supplied staff workbook or identifier list shall auto-create accounts.	S2 #1
FR-AUTH-04	Admin shall edit account metadata, deactivate/reactivate accounts and reset passwords. Physical deletion shall be represented as deactivation so historical actor references remain intact.	S2 #1; engineering
FR-AUTH-05	An admin password reset shall issue/set a temporary credential and require the user to change it at next login; the admin shall never be able to retrieve the current password.	Engineering security baseline
FR-AUTH-06	All account creation, edit, reset, activation/deactivation and delegation actions shall be written to the audit log.	S2 #1,#21
FR-AUTH-07	The application shall lock or rate-limit repeated failed login attempts and use generic authentication errors.	Engineering security baseline
FR-AUTH-08	A user session shall be invalidated when the account is deactivated or a password is reset.	Engineering security baseline
FR-AUTH-09	Role and department changes shall take effect on the next authorization check/session refresh and shall be audited.	Engineering security baseline
FR-AUTH-10	There shall be no public/self-service Admin registration route. The first privileged Admin shall be created only through a controlled backend/bootstrap command.	Engineering security decision
FR-AUTH-11	The bootstrap Admin shall use a temporary password, must_change_password=true, ADMIN role and Manage Admins privilege.	Engineering security decision
FR-AUTH-12	Only an active Admin with Manage Admins privilege may create/deactivate another Admin or change the Manage Admins permission.	Engineering security decision
FR-AUTH-13	The system shall reject any operation that would leave zero active Admins with Manage Admins privilege.	Engineering availability/security decision

5.2 Annual employee data import

ID	Requirement	Source
FR-IMP-01	The system shall support one controlled full-snapshot import for each annual dataset/cycle, nominally dated 1 July.	S2 #3,#4,#14
FR-IMP-02	The operational application shall not expose a general end-user Excel upload in v1; import is performed by an authorized technical operator/script.	S2 TR-06 context
FR-IMP-03	Every import shall create an ImportBatch record containing year, source filename, source checksum, operator, timestamp, row counts and status.	Engineering
FR-IMP-04	Rows shall first be loaded into staging and validated before becoming active annual snapshots.	Engineering
FR-IMP-05	Personnel Number shall be required and unique within the annual snapshot.	S2 #16; S3

ID	Requirement	Source
FR-IMP-06	The value "10" in performance rating and department shall be normalized to NULL.	Stakeholder #1,#9
FR-IMP-07	The importer shall preserve Arabic text in UTF-8 and convert Excel qualification-date values to dates where valid.	S3; Engineering
FR-IMP-08	Unmapped department values shall be reported and shall not be eligible for workflow routing until mapped to an approved department.	Engineering safeguard
FR-IMP-09	Existing completed/request snapshots shall remain unchanged after a later annual dataset is imported.	S2 NFR-06
FR-IMP-10	The application shall retain Employee identity separately from annual Employee Snapshot so the same person can have multiple yearly snapshots.	S2 #16; Engineering

5.3 Employee Affairs functions

ID	Requirement	Source
FR-EA-01	Employee Affairs shall create a new request by choosing Secondment or Promotion and the cycle year, then enter/search the first Personnel Number. The system shall derive the request routing unit from the employee annual snapshot as stated by the BRD.	S1 pp2-4
FR-EA-02	Employee Affairs shall enter one or more Personnel Numbers. For each valid number the system shall return the read-only annual employee data used by the form, including name, current job, level/subgroup, organizational/routing data, latest performance rating and original qualification/date fields available in the approved snapshot.	S1 p2
FR-EA-03	Employee details retrieved from the annual snapshot shall be read-only within the request and copied into an immutable request snapshot at submission.	S1 p4; S2 NFR-06
FR-EA-04	After the first employee establishes the request routing unit, the system shall reject adding another employee whose mapped routing unit differs; one form contains multiple employees from the same routing unit.	BR-002
FR-EA-05	Employees shall be grouped in the request/printout by approved job-title category such as مدير إدارة, رئيس قسم, نمطي أول, نمطي ممتاز and نمطي ماهر.	S2 #8,#18; S3
FR-EA-06	When performance rating is ديج, the system shall show an explicit warning and require the officer to acknowledge it before continuing.	S2 BR-ORG-05
FR-EA-07	Employee Affairs shall submit the request into the configured workflow and receive an in-app confirmation.	S1 workflow
FR-EA-08	The originating Employee Affairs officer shall be able to view current stage, current assignee/owner and complete status history for the request.	S2 NFR-04,#15
FR-EA-09	When the request is returned/rejected, it shall return to the same originating Employee Affairs user with the reason visible.	S2 NFR-04,#13
FR-EA-10	On a returned request, Employee Affairs shall choose Restart or Cancel. Restart creates a new iteration and may pre-populate the prior values for correction.	S2 #28
FR-EA-11	Employee Affairs shall be able to recall any non-final request; the recall reason shall be recorded and the workflow shall restart from the beginning.	S2 BR-EA-09

ID	Requirement	Source
FR-EA-12	In promotion, the intermediate Employee Affairs stage shall review Organization data and explicitly approve forwarding to the Approving Authority or return it for correction.	Stakeholder #3
FR-EA-13	At final approval, Employee Affairs shall approve the final results per candidate/request and freeze the approved snapshot.	S1 workflow; S2 BR- EA-12
FR-EA-14	The routing unit shall normally be determined automatically from Personnel Number/annual snapshot data rather than manually typed. If the source value is missing/unmapped, the request cannot proceed until the controlled mapping is resolved.	S2 #10; stakeholder follow-up
FR-EA-15	After routing unit resolution, the creation flow shall show a controlled Approving Authority drop- down filtered to active manual authority assignments for that routing unit. If exactly one active primary authority exists, it should be preselected but still displayed.	S6 + stakeholder follow-up
FR-EA-16	The legacy/final form requires a controlled subsection/job-category drop-down. The system shall support the approved categories; for secondment this grouping is selected during Organization preparation with the proposed job data. Promotion grouping shall be carried in the form preparation data without overriding the Approving Authority's final same/other-position decision.	S2 #18; S4

5.4 Organization functions

ID	Requirement	Source
FR-ORG-01	Organization users shall have an unassigned work queue for requests at an Organization stage.	Stakeholder #4
FR-ORG-02	An Organization user shall claim an unassigned request using an atomic operation that prevents two users from taking the same request.	Stakeholder #4; Engineering concurrency
FR-ORG-03	After claim, all Organization users shall see the name/ID of the user who took the request.	Stakeholder #4
FR-ORG-04	For secondment, Organization shall add any number of manually entered candidate vacant positions per employee.	S1 p3; S2 BR- ORG-02
FR-ORG-05	Each secondment candidate position shall include position title and organizational affiliation/dependency as manually entered fields.	S1 pp3, final form S4
FR-ORG-06	Organization shall record qualification-compliance as غير مستوفي or مستوفي as a manual human judgment.	S4; S2 BR- ORG-05/06
FR-ORG-07	The application may provide a performance-based suggestion/warning, but Organization retains authority to proceed or reject/return.	S2 BR-ORG-05/06
FR-ORG-08	After the Approving Authority selects a secondment position, Organization shall review/confirm the selection and shall not silently change the Approving Authority decision.	S2 BR-ORG-08
FR-ORG-09	Organization may return/reject according to workflow rules; the action shall include a reason and return to the originating Employee Affairs user.	S2 BR-ORG-09
FR-ORG-10	For promotion, Organization shall review the request/form preparation data and forward it to the intermediate Employee Affairs review stage or return/reject with reason. The final Same Position / Other Position choice is not made by Organization; stakeholder clarification assigns that decision to the Approving Authority.	S2 routing + Stakeholder #3

ID	Requirement	Source
FR-ORG-11	For secondment, vacancy Position Title and Organizational Dependency shall be free/manual text fields entered by Organization; Qualification Compliance shall be a controlled drop-down with مستوفي / غير مستوفي.	S4
FR-ORG-12	For secondment, Organization shall select the form subsection/job category from the approved drop-down while entering proposed vacancies. Arbitrary subsection labels are not allowed; changes are audited.	S4 + data- integrity baseline

5.5 Approving Authority functions

ID	Requirement	Source
FR-DEP-01	The backend shall route approval work using the request routing_unit_id and its selected ApprovingAuthorityAssignment, including any valid delegation.	S2 BR-DEP-01
FR-DEP-02	An Approving Authority shall see only requests covered by that user's active authority assignments/delegations.	S2 BR-DEP-02
FR-DEP-03	The Approving Authority shall make decisions per employee rather than only one batch decision for the entire form.	S2 BR-DEP-09
FR-DEP-04	For secondment, the Approving Authority shall select exactly one Organization-proposed position when approving that employee.	S1 p3
FR-DEP-05	The Approving Authority shall be able to reject an employee/request and shall be required to enter a reason.	S2 BR-DEP-04
FR-DEP-06	The Approving Authority shall be able to return for correction with a reason.	S2 BR-DEP-05/06
FR-DEP-07	For promotion, the Approving Authority shall choose Same Position or Other Position; Other Position requires entering the target job title.	S2 BR-ORG-10/11
FR-DEP-08	After a Approving Authority submits a decision, the decision is locked for that iteration. A correction requires return/restart rather than editing submitted history.	S2 BR-DEP-07 + restart rules
FR-DEP-09	Admin shall be able to configure a temporary delegated Approving Authority for a specific authority assignment/routing unit and later deactivate the delegation; delegate identity and actions shall be audited.	S2 BR-DEP-08
FR-DEP-10	The Approving Authority role shall be backed by an explicit manual Admin configuration linking an active application user to one or more routing units with authority kind (Deputy/Assistant/acting equivalent), descriptive job title and effective status. No authority assignment shall be inferred from spreadsheet job-title text.	S6 + engineering
FR-DEP-11	An authority user may cover multiple routing units when manually configured. Authorization shall be derived from ApprovingAuthorityAssignment records rather than a single department field or textual job title.	S6 + engineering correction

5.6 Notifications

ID	Requirement	Source
FR-NOT-01	Notifications in v1 shall be in-app only.	S2 #20
FR-NOT-02	A user shall receive a notification when a request becomes actionable for that user/role.	S1 p4,p6

ID	Requirement	Source
FR-NOT-03	The originating Employee Affairs user shall be notified of reject, return, cancellation, recall consequences and final completion.	S2 NFR-04
FR-NOT-04	Organization users shall be notified/able to see new unassigned Organization work; when a request is claimed, the assignee shall be visible.	Stakeholder #4
FR-NOT-05	The responsible Approving Authority shall be notified when a request reaches the Approving Authority stage.	S1 notification requirement
FR-NOT-06	Notifications shall include request number, type, department, event/stage, actor when relevant, timestamp and a link to the request.	Engineering
FR-NOT-07	Notifications shall have read/unread state and shall not substitute for the immutable audit log.	Engineering

5.7 Phase 2A REST contract already implemented

Area	Endpoint / behavior
Authentication	POST /api/auth/login; GET /api/auth/me; POST /api/auth/change-password; POST /api/auth/select-active-role; POST /api/auth/logout
Admin users	Explicit GET/POST/PATCH and role/enable/disable/unlock/reset-password routes; no public registration and no generic persistence CRUD.
Authority / delegation	Explicit list/create/update/deactivate routes under /api/admin; activeRole=ADMIN required; sensitive Admin management additionally requires canManageAdmins.
Health	GET /health and GET /ready.
Session contract	Opaque HttpOnly session cookie + JS-readable CSRF cookie; X-CSRF-Token required for cookie-authenticated mutations; trusted Origin enforced.

6. Workflow specifications and signoff semantics

6.1 Promotion workflow

Stage	Actor	Primary responsibility	Official-form signoff effect
P1	Employee Affairs	Create request; set month/year; lookup/add eligible employees; review snapshot data; add notes; sign and submit.	Mandatory EA signoff displayed in the official form.
P2	Organization	Claim request; review/prepare Organization data; add notes; sign and submit.	Mandatory Organization signoff displayed in the official form.
P3	Employee Affairs	Review Organization data and approve forwarding or use permitted return/rejection actions.	Audit/workflow approval only; does not replace P1 signer.
P4	Approving Authority	Per employee choose same-position or other-position promotion; manually type target job when other-position; notes/approve/reject/return.	Decision appears in form; no additional visual signature block in current official template.
P5	Employee Affairs	Final confirmation/approval; view, print and download frozen final official PDF.	Final approval recorded in audit; visible EA block remains P1 signer.

6.2 Secondment workflow

Stage	Actor	Primary responsibility	Official-form signoff effect
S1	Employee Affairs	Create request; set month/year; lookup/add eligible employees; review snapshot data; add notes; sign and submit.	Mandatory EA signoff displayed in the official form.
S2	Organization	Claim request; choose form subsection; enter unlimited proposed positions and organizational dependencies; choose / مستوفي غير مستوفي; add notes; sign and submit.	Mandatory Organization signoff displayed in the official form.
S3	Approving Authority	Review Organization proposals and choose exactly one proposed position per employee; notes/approve/reject/return.	Decision appears in form/audit; no authority signature block in current official form.
S4	Organization	Post-authority review/confirmation; cannot silently replace authority selection; notes/return/reject as permitted.	Audit/workflow approval only; visible Organization block remains S2 signer.
S5	Employee Affairs	Final confirmation/approval; view, print and download frozen final official PDF.	Final approval recorded in audit; visible EA block remains S1 signer.

6.3 Mandatory signature rule

P1/S1 and P2/S2 cannot be submitted without an authenticated signer name, per-signoff job-title value and valid immutable signature asset. Signer name defaults from the account and cannot be manually changed; job title defaults from the profile but may be overridden only for that signoff.

6.4 Return, rejection, recall and restart semantics

- Return for correction and Reject create an actionable item for the originating Employee Affairs user and preserve the reason.
- Employee Affairs chooses Restart or Cancel after a return/rejection. Restart increments iteration_number and begins at the Employee Affairs start stage.
- Recall may be initiated by Employee Affairs at any non-final stage and creates a new iteration from the beginning.
- Submitted stage decisions remain immutable in old iterations; corrected values are captured in the new iteration.
- Request-level status is derived from the active iteration: Draft, In Progress, Returned, Cancelled or Completed; detailed stage status is maintained separately.

7. Stage-received PDF, draft/final PDF and workflow notes

7.1 View as PDF for every workflow actor

- Employee Affairs, Organization and Approving Authority each have a View as PDF action for workflow tasks they receive.
- The action renders the official form from an immutable stage-received snapshot captured when that actor receives/claims the task.
- The PDF shows exactly the business data available at receipt time; later edits do not alter the historical received-stage PDF.
- Fields owned by later stages remain blank while preserving the official form structure.
- Authorized users can reopen their own received-stage PDF snapshots from request history/timeline.

7.2 Draft and final official form

- At P1/S1, Employee Affairs can preview, print and download a draft official form while preparing the request.
- At P5/S5, Employee Affairs can view, print and download the frozen final official form.
- The final PDF freezes request, candidate, decision, visible signoff and printed-note data from the final completed iteration.
- Employee Affairs and Organization signatory blocks appear on one horizontal row using P1/S1 and P2/S2 signoffs respectively.
- Audit-log PDF remains a separate printable/downloadable document.

7.3 Workflow notes/messages

- Any operational workflow actor may append a note/message at their stage.
- Notes are append-only; one actor cannot overwrite another actor's prior message.

- Each note records author account, active role, stage/task, server timestamp, request/iteration and optional candidate scope; creation is audited.
- Request-level notes act as messages to later actors and appear in workflow history/message UI.
- Every candidate-level note is part of the official candidate record and renders chronologically in the candidate ملاحظات column; there is no print/include toggle.

8. Data and PostgreSQL requirements

8.1 Annual Excel import and routing rules

Rule	Final requirement
Authoritative dataset	The approved annual eligible workbook is the operational population for v1. The broader company workbook is not used to decide eligibility.
Expected headers	Validate required business header names before staging. Match values by header name; do not rely on fixed column order.
Blank normalization	Trim strings; blank/whitespace performance-rating and routing-unit values become NULL. Literal "10" also becomes NULL if encountered.
Personnel Number	Required and unique within annual batch; employee identity remains stable while annual snapshot is keyed by year + personnel number.
Unknown routing labels	Block the affected row from workflow activation until an explicit source-label alias maps it to an approved routing unit or EGAS formally adds a new unit.
No inferred employee administration	Do not fabricate employee النيابة or التبعية التنظيمية from الإدارة. Those fields are absent from the current authoritative source.
Secondment dependency	The organizational dependency of each proposed secondment position is manually entered by Organization.
Authority workbook	Reference-only; never parsed to grant permissions or auto-create Approving Authority accounts.
Import UI	Admin/operator sees validation totals, blocked rows, warnings, unmapped source labels and explicit activation action.

8.2 Source workbook mapping

Excel Column	Target Model	Rule
رقم الموظف	Employee.personnel_number	Required; unique employee business identifier and unique within annual snapshot.
اسم الموظف	EmployeeAnnualSnapshot.employee_name	Preserve Arabic text exactly after whitespace normalization.
المجموعة الفرعية	EmployeeAnnualSnapshot.subgroup	Store source value; do not independently use it to exclude employees in v1.
النيابة / المساعد	EmployeeAnnualSnapshot.source_department + mapped routing_unit_id	Blank/whitespace -> NULL; literal "10" -> NULL if encountered. Non-null source value must map to an approved workflow routing unit before use.
الوظيفة	EmployeeAnnualSnapshot.current_job_title	Store full Arabic text.
تقرير كفاية 2026	EmployeeAnnualSnapshot.performance_rating	ممتاز / جيد جدا / جيد; blank or source "10" -> NULL.
المؤسسة التعليمية-المؤهل الأصلي	EmployeeAnnualSnapshot.qualification_source_1	Preserve source label/value; exact HR semantic name can be refined later without losing data.
الشهادة-المؤهل الأصلي	EmployeeAnnualSnapshot.qualification_source_2	Preserve source label/value.
تاريخ المؤهل الأصلي	EmployeeAnnualSnapshot.qualification_date	Nullable date.

8.3 Core entities

Entity	Purpose / Key Fields
Employee	Stable identity: internal UUID + unique Personnel Number.

Entity	Purpose / Key Fields
EmployeeAnnualSnapshot	Immutable yearly row: employee, year, name, subgroup, department mapping, current job, performance, qualification fields, source row.
RoutingUnit	Approved / values used for routing. Stores Arabic name, active status النياية المساعد / and optional unit-kind metadata.
UserAccount	Local application account manually created by Admin: username, staff identifier, display name, optional descriptive job title, password hash, active state and must-change-password flag. Role assignments are stored separately in user_account_role.
AuthorityDelegation	Temporary audited delegation tied to a specific ApprovingAuthorityAssignment.
WorkflowRequest	Form header: type, cycle year, routing unit, selected approving-authority assignment + frozen authority snapshots, creator, status/current stage/current iteration, timestamps.
RequestCandidate	Employee included in a request, linked to annual snapshot and frozen candidate snapshot fields.
WorkflowIteration	Restart-safe workflow pass, iteration number and lifecycle state.
StageTask	Current/actionable stage task, claim/assignee, timestamps and state.
SecondmentPositionOption	Unlimited manual options per candidate, org dependency, qualification-compliance, selected flag.
PromotionDecision	Same/Other position decision and target title.
Notification	In-app recipient notification and read state.
AuditEvent	Append-only event with actor, action, request/stage, reason, metadata/diff, timestamp and hash-chain fields.
ImportBatch / ImportStagingRow	Annual eligible employee .xlsx import metadata plus raw staging/validation rows; no account or authority auto-import.
PdfGenerationLog	Records generated report type, filter/request scope, template version, actor, timestamp and document hash.
RoutingUnit	The 22 approved / routing values used by forms and workflow النياية / routing.
ApprovingAuthorityAssignment	Manual Admin configuration mapping a routing unit directly to an active Approving Authority user, authority kind and descriptive job title/effective status; the same user may cover multiple routing units.
AuthorityDelegation	Temporary audited delegation for an Approving Authority assignment without rewriting the primary assignment history.
RequestFormSection	Request subsection selected from the approved job-category reference; candidates link to sections for grouping/printing.

8.4 Key data constraints

ID	Requirement	Source
DR-001	Employee.personnel_number shall be globally unique in the application.	S2 #16
DR-002	EmployeeAnnualSnapshot shall be unique on (snapshot_year, personnel_number).	Engineering
DR-003	request/candidate/iteration/audit records shall reference valid routing/authority context; completed records shall preserve frozen snapshots rather than rely on later configuration.	BR-002
DR-004	Completed request/candidate/decision records shall not be updated by ordinary workflow operations.	S2 #7
DR-005	AuditEvent shall be append-only; no normal role including Admin shall have update/delete operations on audit events.	S2 NFR-05

ID	Requirement	Source
DR-006	Stage claim shall be protected with a database transaction/compare-and-set rule so only one Organization user can claim an unassigned task.	Stakeholder #4
DR-007	Indexes shall support Personnel Number lookup, request status/stage, routing- unit/period filtering, assigned-user queues, request history and audit filtering.	Engineering
DR-008	All database text storage shall support Unicode/UTF-8 Arabic data.	S3
DR-009	Each active routing unit shall have at most one active primary ApprovingAuthorityAssignment; pilot preflight shall verify complete coverage.	Routing integrity
DR-010	An authority person/user may be primary for more than one routing unit; no uniqueness constraint shall prohibit this.	S6 combined responsibilities
DR-011	WorkflowRequest shall store the selected ApprovingAuthorityAssignment and frozen authority staff identifier/name/manual job-title/authority-kind snapshots so later account or assignment changes do not rewrite history.	Historical integrity
DR-012	RequestFormSection.job_category shall reference only مدير إدارة, رئيس قسم, نمطي أول, نمطي ممتاز, نمطي ماهر.	S2 #8; S4

8.5 Implementation schema authority

The original PostgreSQL logical schema v1.0 FINAL remains a historical/conceptual model reference. After CAP removal, the implementation schema authority is the current PostgreSQL physical schema plus versioned SQL migrations under services/api. Applied migrations are checksum-tracked and must not be silently edited or replayed against the live database.

Historical CAP tables

cds_model and cds_outbox_messages are retained only as historical physical artifacts. The restricted runtime role egas_app has no access to them, and normal application code does not query them.

9. Search, reporting and PDF requirements

9.1 Search and history

ID	Requirement	Source
FR-SRCH-01	Authorized users shall search requests by request number, type, cycle year, department, employee Personnel Number, employee name, current stage/status and date period.	S1 p6; S2 #15
FR-SRCH-02	Search results shall respect role scope; backend authorization shall be applied before returning rows.	NFR-04
FR-SRCH-03	Employee Affairs shall see the complete lifecycle of owned requests, including prior iterations and return reasons.	S2 NFR-04,#15
FR-SRCH-04	Admin shall have system-wide search and audit filters.	S2 admin scope
FR-SRCH-05	History shall show current stage for in-progress requests and final outcome for completed/cancelled requests.	S2 #15

9.2 Management dashboard (proposed MVP)

- Pending requests by workflow and current stage.
- Unassigned Organization queue and currently claimed Organization workload.
- Requests created/completed/cancelled/returned/rejected by period and routing unit.
- Average and median workflow cycle time by workflow and routing unit.
- Aging list for requests remaining in the same stage longer than a configurable threshold.
- Promotion vs Secondment volume by month/quarter/year.
- Performance-warning counts (جيد or missing) by cycle, for process oversight only.
- Annual import status: active snapshot year, row counts, validation issues and import timestamp.

9.3 Final form PDF

ID	Requirement	Source
FR-PDF-01	The system shall generate a redesigned digital Arabic PDF rather than requiring an exact pixel replica of the legacy paper form.	Stakeholder #6
FR-PDF-02	The final form shall preserve the official business information represented in S4 and group employees by job-title category.	S4; S2 #18
FR-PDF-03	Promotion PDF shall include request/department/cycle header, candidate name, current job, qualification fields, performance data, same/other-position decision, target position when applicable, notes and approval summary.	S4 + S2
FR-PDF-04	Secondment PDF shall include candidate name, current job, proposed/selected vacant positions, organizational dependency, qualification-compliance, notes, qualification fields, performance data and approval summary.	S4 + S2
FR-PDF-05	The final PDF shall contain a concise approval section listing involved parties/actors, user ID, role, decision and date/time; detailed technical history belongs in the separate Audit Log PDF.	S2 BR-EA-08 + stakeholder #6
FR-PDF-06	PDF generation shall be on demand. For completed requests the PDF shall always use the frozen approved snapshot.	S2 NFR-07,#7
FR-PDF-07	The PDF renderer shall correctly shape Arabic, use RTL layout and support multi-page tables without clipped rows.	UI requirement
FR-PDF-08	A field noted in the legacy promotion form as "تقرير آخر ترقية" shall be preserved as a configurable/manual field until its authoritative source/format is confirmed.	S4 open item

9.4 Audit Log PDF

ID	Requirement	Source
FR-AUDPDF-01	Audit log printing shall be separate from the final business form.	Stakeholder #6
FR-AUDPDF-02	A user with permission shall print the complete audit history for one promotion/secondment request.	Stakeholder #6
FR-AUDPDF-03	Admin/authorized reporting users shall print an audit report covering multiple requests within the same department.	Stakeholder #6
FR-AUDPDF-04	Department audit filters shall support daily, weekly, monthly, quarterly, half-yearly and yearly periods.	Stakeholder #6
FR-AUDPDF-05	Each audit row shall identify request, employee/candidate when applicable, actor name, actor/user ID, role, action, from/to stage, outcome/reason and timestamp.	S2 #21

ID	Requirement	Source
FR-AUDPDF-06	For incomplete requests, the report shall clearly identify the current in-progress stage; for completed requests, all completed stages shall appear.	S2 #15

10. Security requirements

10.1 Core security requirements

ID	Requirement	Source
SEC-001	Passwords shall never be stored in plaintext or with a general-purpose fast hash such as raw SHA-256. Use a salted adaptive password-hashing algorithm; Argon2id is the preferred baseline.	OWASP Password Storage; correction to S2 #67
SEC-002	Authentication cookies/session identifiers shall be random, unguessable, HttpOnly, Secure when HTTPS is enabled, and protected with SameSite settings appropriate to the internal deployment.	Engineering
SEC-003	Server-side authorization shall enforce role, request ownership/assignment and department scope on every protected service/action.	S2 NFR-04; engineering authorization baseline
SEC-004	Secrets such as database passwords and signing/session secrets shall be supplied through server secret/environment configuration and shall never be committed to Git.	Correction to S2 #68
SEC-005	The application shall use TLS/HTTPS on the internal network for production-like operation.	Corporate security baseline
SEC-006	Audit events shall be append-only and tamper-evident. A hash chain may use SHA-256 because this is integrity protection, not password storage.	S2 NFR-05; Engineering
SEC-007	Sensitive operational logs shall not contain plaintext passwords, session tokens or database secrets.	Engineering
SEC-008	All data-changing actions shall validate input lengths/enums/state transitions on the backend.	Engineering
SEC-009	The application shall protect against IDOR by deriving role/ownership scope from the authenticated user rather than trusting client-supplied user IDs.	Engineering
SEC-010	The application shall apply CSRF protection appropriate to its cookie/session design and shall use restrictive CORS if frontends and API use separate origins.	Engineering
SEC-011	Admin account-management actions and authentication events shall be security logged.	S2 #1; OWASP ASVS baseline
SEC-012	Production release shall include dependency/vulnerability review and source-control secret scanning.	Engineering

10.2 Security hardening baseline

The following v1.6 hardening requirements remain authoritative, with architecture-specific wording updated to the v3.0 Express/pg implementation. The security intent is unchanged.

ID	Control	Requirement
SEC-HARD-001	Deny-by-default server authorization	Every non-public backend service/action shall authenticate the session and authorize the role, routing-unit scope, request ownership/assignment, active delegation and current workflow stage before reading or changing protected data. Hidden buttons or routes in React are UX only and never a security boundary.
SEC-HARD-002	No direct browser-to-database access	React applications shall communicate only with the Node.js/Express backend. No PostgreSQL credentials, connection strings, service-role credentials or database keys shall be embedded in frontend code, public build-time variables, browser storage or Stitch/Codex prompts.

ID	Control	Requirement
SEC-HARD-003	Data minimization	The application shall store only fields required for the promotion/secondment workflow, audit, reporting and approved account management. Additional HR fields from broader workbooks shall not be imported merely because they exist.
SEC-HARD-004	Defense in depth	Security shall combine backend authorization, least-privilege database access, validated state transitions, optional PostgreSQL RLS for safely expressible row scopes, audit logging, HTTPS, secure sessions, input/output controls and deployment hardening.
SEC-HARD-005	Secrets outside Git	Database passwords, session/signing secrets, encryption keys and future external-service credentials shall be supplied through machine-local or approved secret-management configuration. .env containing real values shall be ignored by Git; .env.example may contain names/placeholders only.
SEC-HARD-006	Frontend values are not secrets	Any variable delivered to browser JavaScript shall be considered public. A frontend API base URL may be public; credentials and privileged tokens may not.
SEC-HARD-007	Secret scanning before push and release	The repository shall run automated secret scanning locally and/or in CI. GitHub push protection/secret scanning should be enabled when available. The repository shall expose a stable command such as npm run security:secrets for repeatable checking.
SEC-HARD-008	Leaked-secret response and Git purge	If a real secret is committed, the secret shall be treated as compromised: revoke/rotate it immediately, update runtime configuration, remove it from Git history using an approved history-rewrite procedure, force-update affected refs if necessary, rescan branches/tags and record the incident. Deleting the value in a later commit is not sufficient.
SEC-HARD-009	Password hashing, not encryption	Passwords shall never be reversibly encrypted and shall never use raw SHA-256. Store only salted adaptive password hashes; Argon2id is the preferred baseline. Password reset shall create a temporary credential or controlled reset flow and require change at first login.
SEC-HARD-010	Secure session cookies	Authenticated browser sessions shall use an opaque random session identifier in an HttpOnly cookie. Secure shall be enabled for HTTPS environments. SameSite shall be Strict where compatible or Lax when required by the selected login flow. Session tokens shall never be stored in localStorage/sessionStorage.
SEC-HARD-011	Session lifecycle	Sessions shall have configurable idle and absolute lifetimes. Engineering defaults are 30 minutes idle and 8 hours absolute pending EGAS IT approval. Session identifiers shall rotate after login, password change and privilege-sensitive account changes. Logout, password reset, account deactivation and relevant role changes shall revoke server-side sessions.
SEC-HARD-012	Login rate limiting and logout	Login shall be rate-limited by account identifier and source IP. Engineering baseline: after 5 failed attempts within 10 minutes, temporarily lock the account for 15 minutes; values remain configurable by EGAS IT. Responses shall not reveal whether a username exists.
SEC-HARD-013	Anti-automation/bot protection	Use progressive throttling, temporary logout and suspicious-attempt detection before introducing an interactive challenge. CAPTCHA or another challenge may be enabled conditionally if EGAS IT requires it, but the offline/local pilot shall not depend on an external bot service.
SEC-HARD-014	CSRF protection	Cookie-authenticated state-changing requests shall use an appropriate CSRF defense such as same-site cookies plus a server-issued CSRF token/validated origin strategy. GET/HEAD endpoints shall not mutate workflow state.

ID	Control	Requirement
SEC-HARD-015	Object-level authorization / IDOR prevention	Every request, candidate, audit report, PDF, notification and account-management object shall be re-authorized on the server using the authenticated identity and current scope. Client-supplied user IDs, role names, routing units, request owners or authority identifiers shall never be trusted as proof of access.
SEC-HARD-016	Field allow-listing / mass-assignment prevention	Write endpoints shall accept explicit DTOs/allow-lists only. Protected fields such as actor, created_by, workflow status, current stage, employee name/job, annual snapshot values, authority assignment and timestamps shall be derived by the server rather than accepted from arbitrary client payloads.
SEC-HARD-017	Record concurrency control	Mutable workflow records shall use transactional conditional updates, row locks where required and/or optimistic version checks. Organization Take Request must remain atomic. Conflicting stale edits shall return a safe conflict response instead of silently overwriting another user.
SEC-HARD-018	PostgreSQL Row Level Security	RLS shall be implemented as defense-in-depth on sensitive tables whose row scope can be safely expressed after the backend authentication/authorization establishes the trusted user/active-role context used for the transaction. The application DB role shall not be a superuser, table owner or possess BYPASSRLS. RLS policies shall be covered by automated tests. Backend authorization remains mandatory even when RLS is active.
SEC-HARD-019	Parameterized database access	The pg repository layer shall use parameterized SQL/bound values for data access. Any handwritten SQL shall use bound parameters; concatenating untrusted input into SQL text is prohibited.
SEC-HARD-020	Validate every external input	Backend validation shall cover body fields, query parameters, path identifiers, filters, enum values, dates, pagination, notes, job titles, organization text, Excel workbook values, filenames and Admin configuration. Reject unexpected fields and values outside defined length/range/format limits.
SEC-HARD-021	Output encoding and XSS prevention	User-controlled notes, reasons, job titles, display names and organizational text shall be rendered through safe React text binding/contextual encoding. Unsafe raw HTML rendering of user data is prohibited. If HTML sanitization is ever required, it shall use an approved sanitizer and narrowly defined allow-list.
SEC-HARD-022	Minimal API responses	API responses shall use explicit response DTOs/projections and return only fields required by the caller. Database entities shall not be serialized blindly. Password hashes, internal session data, unnecessary HR fields and internal authorization metadata shall never be returned to browsers.
SEC-HARD-023	Request and query resource limits	Set safe limits for JSON/body size, query-string length, page size, date/report range, search length and computationally expensive operations. Unbounded list endpoints are prohibited.
SEC-HARD-024	Safe error handling	Client errors shall use generic structured messages and correlation IDs without stack traces, SQL text, file-system paths, secret values or internal implementation details. Detailed diagnostics remain in protected server logs.
SEC-HARD-025	Restricted file types	The annual import shall accept only the approved .xlsx workflow workbook format. Reject executable content, .xslm/macro-enabled files and unrelated attachments unless a later requirement explicitly authorizes them.
SEC-HARD-026	File verification and size limits	Validate extension, file signature/container structure, maximum file size, expected worksheet/header structure, row limits and data types before activation. Do not rely solely on browser MIME or filename.
SEC-HARD-027	Controlled storage and filenames	Imported files, if temporarily retained, shall use server-controlled filenames/paths outside the public web root with restricted permissions and lifecycle cleanup. Original client paths/filenames shall not determine server storage locations.

ID	Control	Requirement
SEC-HARD-028	Staging before activation	No spreadsheet row becomes authoritative HR data directly. Store raw staging rows, validate/normalize according to approved rules, show an import summary, and activate a full annual snapshot only after validation succeeds.
SEC-HARD-029	HTTPS/TLS	Production-like internal operation shall force HTTPS. HTTP may be used only for isolated localhost development. The reverse proxy shall redirect/reject plaintext production traffic and use HSTS after HTTPS is correctly deployed.
SEC-HARD-030	Private database connectivity	PostgreSQL shall listen only on approved/private interfaces and be protected by host/network controls. The application uses a least-privilege DB login; operational users never connect directly to PostgreSQL for normal workflow use.
SEC-HARD-031	Encryption at rest and backups	Production database volumes and backup media/files shall use approved platform/storage encryption where available. Backups shall be access-controlled like the live database and shall not be committed to Git. Separate encryption keys/secrets from encrypted data where platform capability permits.
SEC-HARD-032	Application-level field encryption only when justified	If EGAS later requires storage of fields whose confidentiality warrants application-level encryption, use an approved authenticated encryption scheme and managed keys. Do not introduce reversible encryption for passwords.
SEC-HARD-033	Content Security Policy	Serve a restrictive CSP compatible with React, disallowing unsafe inline/eval behavior unless a documented technical exception is required. Prefer self-hosted/internal resources for the pilot.
SEC-HARD-034	Baseline headers	Production responses shall include appropriate X-Content-Type-Options: nosniff, frame protection via CSP frame-ancestors (and/or compatible X-Frame-Options), Referrer-Policy, Permissions-Policy and HSTS when HTTPS is active.
SEC-HARD-035	Restrictive CORS	If the Admin Portal, Workflow Portal and API use different origins, allow only explicitly configured approved origins/methods/headers and credential behavior. Wildcard CORS with credentials is prohibited.
SEC-HARD-036	Security event logging	Security logs shall cover successful/failed login, logout, password reset/change, session revocation, Admin creation/deactivation, Manage Admins changes, authority mapping/delegation changes, denied authorization attempts, annual import activation/failure and security-sensitive configuration changes.
SEC-HARD-037	Log minimization and masking	Never log plaintext passwords, session tokens, CSRF tokens, database credentials, encryption keys or complete sensitive request bodies. Mask/truncate identifiers where full values are not operationally necessary and use correlation IDs for troubleshooting.
SEC-HARD-038	Audit immutability	Business audit_event records remain append-only/tamper-evident. The application database role shall not receive normal UPDATE/DELETE permission on audit_event. Audit and security logging serve different purposes but may share correlation/request identifiers.
SEC-HARD-039	Lockfile and reproducible install	Commit the package lockfile and use reproducible dependency installation in CI/pilot setup. Do not silently install arbitrary latest versions during deployment.
SEC-HARD-040	Dependency and code scanning	Before pilot release and production deployment, run dependency vulnerability scanning, secret scanning and appropriate static/code-quality checks. High/critical findings affecting reachable runtime code shall be resolved or explicitly risk-accepted before release.

ID	Control	Requirement
SEC-HARD-041	No production debug exposure	Production/pilot mode shall not expose development stack traces, debug endpoints, unrestricted database consoles, hot-reload servers or unauthenticated API explorers. Public source maps shall be disabled unless protected/required for internal diagnostics.
SEC-HARD-042	Stable security commands	The repository shall provide repeatable scripts such as <code>npm run security:secrets</code> , <code>npm run security:scan</code> and <code>npm run security:check</code> , and <code>pilot:check</code> shall include the release-critical subset.
SEC-HARD-043	Automated authorization matrix	Tests shall prove that each role cannot access another role/unit/request outside its permitted scope, including direct URL/API attempts and modified object IDs.
SEC-HARD-044	Security abuse tests	Test login rate limiting/lockout, session invalidation/rotation, CSRF defenses, SQL-injection resistance, mass assignment, XSS/output encoding, oversized inputs, malicious/invalid XLSX, CORS, security headers, HTTPS behavior, RLS policies where enabled, safe errors and dependency/secret scans.
SEC-HARD-045	OWASP ASVS target	Use OWASP ASVS 5.0 Level 2 as the engineering verification target for the production-intended internal HR application, with documented exceptions where an item is not applicable to the selected architecture.
SEC-HARD-046	Production security review	Before production approval with real operational data, EGAS IT/Cybersecurity shall review deployment configuration, TLS, secrets, database permissions/RLS, backup security and vulnerability findings. A penetration/security assessment should be performed according to corporate policy.
SEC-HARD-047	No public database key	The "use a public DB key" pattern is not applicable. This system uses a backend-mediated PostgreSQL architecture. The browser receives no database credential. If the architecture later changes to a BaaS platform, that security model must be reviewed separately rather than copied into the current system.

10.3 v3.0 authentication/session security implementation baseline

- Passwords use Argon2id; plaintext or reversible password storage is prohibited.
- Browser authentication uses opaque 32-byte random server-side sessions; only hashes are persisted.
- Default idle timeout is 30 minutes and default absolute timeout is 8 hours, configurable by approved policy.
- Session cookie is HttpOnly, SameSite=Strict, path=/ and has explicit expiry; Secure is mandatory for production HTTPS.
- CSRF cookie is readable by JavaScript and must match X-CSRF-Token, the stored session CSRF hash and a trusted Origin on mutating requests.
- Five failed login attempts within the default ten-minute window cause a default fifteen-minute restriction; PostgreSQL serialization prevents race bypass.
- One session has exactly one active role. Permissions from assigned roles are never unioned.
- Sensitive account/role/authority/delegation changes rotate or revoke affected sessions and emit security events.

11. Non-functional requirements

11.1 Performance and capacity

ID	Requirement	Source
NFR-PERF-01	On the EGAS LAN, employee lookup by Personnel Number should complete within 1 second at p95 under normal load.	S2 NFR-01 + engineering metric
NFR-PERF-02	Normal workflow read/write actions should complete within 1.5 seconds at p95, excluding PDF generation and large report exports.	S2 NFR-01 + engineering metric
NFR-PERF-03	Initial authenticated application navigation should feel near-instant after assets are cached; normal page transitions should avoid full page reloads.	S2 NFR-01

ID	Requirement	Source
NFR-PERF-04	The design shall comfortably support the stated corporation scale of approximately 1,500 employees; pilot load testing shall use at least 100 concurrent authenticated sessions until IT provides a measured peak.	S2 BR-PO-05 + engineering baseline
NFR-PERF-05	Large request and audit tables shall use server-side pagination/filtering rather than loading unbounded history into the browser.	Engineering

11.2 Availability, reliability and retention

ID	Requirement	Source
NFR-REL-01	Target service availability is 99% during the defined operating period, subject to local infrastructure and pilot constraints.	S2 NFR-02
NFR-REL-02	Database transactions shall ensure stage transitions, claims and audit writes are atomic.	Engineering
NFR-REL-03	Completed request snapshots and audit history shall remain readable after future annual dataset imports.	S2 NFR-06
NFR-REL-04	Pilot backup may be minimal; production backup, restore testing and disaster recovery shall be finalized with EGAS IT before production approval.	S2 TR-20
NFR-REL-05	PDF generation failure shall not modify workflow state; users shall receive a retryable error and the failure shall be logged.	Engineering

11.3 Browser and accessibility

ID	Requirement	Source
NFR-UI-01	Support current company-approved versions of Chrome, Firefox and Edge.	S2 NFR-08
NFR-UI-02	Primary supported viewport is laptop/desktop; core functionality shall remain usable on common large-screen resolutions without horizontal page overflow.	S2 BR- PO-08,NFR-08
NFR-UI-03	The UI shall target WCAG 2.2 Level AA conformance.	S2 NFR-08; WCAG 2.2
NFR-UI-04	Arabic shall be the default interface language and layout direction. English is a future enhancement, but labels/messages should be isolated in translation resources.	S2 BR-PO-03

12. UI/UX and accessibility baseline

- Use React + TypeScript with an EGAS-specific component/design system. SAP UI5 and Fiori runtime dependencies are not permitted by this baseline.
- Approved Stitch/UI handoff images remain the visual and interaction source where compatible with requirements; they do not create runtime dependency on Stitch.
- Use Arabic RTL navigation, tables and forms by default; mixed Arabic/English IDs and numbers must not break ordering.
- Role-specific home screens: Employee Affairs My Requests; Organization Unassigned/My Claimed; Approving Authority routing-unit decisions; Admin Accounts/Authority Mapping/Audit/Reports.
- Prominent status chips for Draft, In Progress, Returned, Cancelled and Completed; show current stage/current assignee where permitted.
- Warnings for performance rating جيد or missing must be visually distinct from blocking validation errors.
- Keyboard navigation, visible focus, accessible labels, contrast and semantic status text shall target WCAG 2.2 AA.
- Long Arabic names/job titles and multi-line organization text must wrap rather than overflow.

12.1 Suggested screen inventory

Portal / Role	Screens
Workflow - Employee Affairs	Login; My Requests; New Request wizard; Request detail/timeline; Returned Request correction/restart; Promotion intermediate review; Final approval; Search/history; PDF actions.
Workflow - Organization	Login; Unassigned queue; My Claimed; Request detail; secondment vacancy editor; qualification-compliance controls; post-Approving Authority confirmation; return/reject.
Workflow - Approving Authority	Login; routing-unit inbox; request/candidate detail; per-employee secondment selection; promotion same/other-position decision; notes/reason; submitted history. Authority scope comes from active assignment/delegation records and may include more than one routing unit.
Admin Portal	Admin login; Users; Create/Edit/Deactivate/Reset; Manage Admins; Routing Units; Approving Authority mapping; Delegation; Audit search/export; Management dashboard; Annual import status; system settings.

13. Deployment and operations

- The v1 application is hosted on EGAS-controlled infrastructure and accessed from the internal network.
- Future VPN access is an approved direction but is not required for pilot acceptance.
- Exact server OS, reverse proxy, container policy and production database host are controlled by EGAS IT and shall not be hard-coded into business logic.
- Configuration and secrets are external to source code. Separate environment configuration is used for development/test/production.
- React frontends and the Express API should be deployed same-origin or through an approved same-origin reverse proxy. CORS is disabled/restrictive by default.
- Annual employee import is a controlled repository-owned XLSX staging/validation/activation procedure. Database GUI tools are troubleshooting aids only.
- Runtime source is stored in a private Git repository; real passwords, HR Excel files, backups and generated real-employee PDFs remain outside Git.
- Normal runtime uses the restricted PostgreSQL role egas_app. Deployment/migration ownership is separate and never used as the application runtime identity.

14. Testing requirements

14.1 Critical functional tests

- Import annual snapshot and confirm blank/"10" normalization, uniqueness and routing mapping validation.
- Employee Affairs creates a multi-employee request for one routing unit and cannot mix incompatible/unmapped routing units.
- Organization claim is atomic; a second user cannot claim the same task and sees the first claimant.
- Secondment supports unlimited position options and Approving Authority selects per employee.
- Promotion follows Employee Affairs -> Organization -> Employee Affairs review -> Approving Authority -> Employee Affairs final.
- جيد rating produces a warning but may proceed after acknowledgement.
- Reject/return with reason reaches originating Employee Affairs; restart creates iteration 2 and preserves iteration 1.
- Recall from each non-final stage restarts from beginning and is audited.
- Final approval freezes data; attempted normal edit/reopen is blocked.
- Final-form PDF is Arabic/RTL, multi-page safe and generated from frozen data; audit PDF supports required filters.

14.2 Critical security tests

- Approving Authority cannot access another routing unit by editing URLs/IDs.
- Employee Affairs cannot access another officer's restricted request through direct API calls.
- Organization cannot edit a request claimed by another user.
- Admin cannot update/delete audit events.
- Passwords are Argon2id/adaptive hashes, not plaintext/raw SHA-256.
- Deactivated/reset-account sessions stop working.
- Secrets are absent from repository/client bundles.
- Invalid workflow state transitions are rejected by backend.
- A multi-role user active as ORGANIZATION receives 403 from Admin routes; active-role permissions are not unioned.
- CSRF, Origin, login-rate, concurrency and error-information leakage controls are regression-tested.

15. Delivery phases and current status

Phase	Scope	Status at v3.0 freeze
1 - Foundation & Database	Repository structure; PostgreSQL; 22 routing units; bootstrap Admin; account/role/authority model; migration runner; least-privilege runtime.	Complete
2A - Authentication & Admin	Local login/session, mandatory password change, active-role selection, Admin users/roles, authority assignments, delegation, security events.	Complete
Architecture migration	Replace SAP CAP/CDS/CQN with Express 5 + pg while preserving PostgreSQL and Phase 2A behavior.	Complete and verified
2B - Data & Routing	Annual employee XLSX staging/validation/activation; routing aliases; employee identity + annual snapshots; employee lookup.	NEXT
3 - Request Core	Workflow Portal shell; Employee Affairs request creation; request/candidate snapshots; status/timeline; in-app notifications.	Pending
4 - Secondment	Organization claim queue; unlimited manual vacancy options; qualification drop-down; authority selection; Organization confirmation; returns/restarts.	Pending
5 - Promotion	Organization stage; intermediate EA review; authority same/other-position decision; target-job entry; final approval.	Pending
6 - Documents & Reports	Received/draft/final PDFs; audit PDF filters; search/history; management dashboard.	Pending
7 - Hardening & UAT	Security controls, performance/load, accessibility, browser matrix, backup/restore, stakeholder UAT and deployment documentation.	Pending

16. Acceptance criteria

- All four application roles authenticate through local accounts and are limited to backend-enforced scopes.
- Admin can create/edit/deactivate/reset accounts and configure roles, authority assignments and delegation with audited changes and Manage-Admins protections.
- The approved annual Excel structure can be imported into PostgreSQL with validation, Arabic preservation and yearly snapshots.
- Secondment and promotion follow the confirmed routes and preserve all return/reject/recall/restart history.
- Organization self-assignment is concurrency-safe and claimant identity is visible to other Organization users.
- Approving Authority sees only work covered by active routing-unit assignments/delegations and decides per employee.
- Completed requests are immutable and regenerate the same approved business data in the final PDF.
- Final business form and separate audit-log PDF meet defined print/filter requirements.
- Search, current-stage tracking and in-app notifications operate for applicable roles.
- Security, accessibility, browser and performance gates pass before pilot/production acceptance.

17. Open items and pre-pilot setup gates

Item	Current treatment / needed decision	Blocking?
تقرير آخر ترقية legacy field	Keep manual/configurable field with exact approved label until HR confirms authoritative source and data type.	No for workflow; yes before final-form sign-off if populated automatically.
Annual dataset owner/operator	System records operator/import metadata; EGAS IT/HR shall assign operational owner before production.	No for development.
Routing-label discrepancies	Rows with unmapped source routing labels remain blocked until explicit approved mapping/correction.	Data setup gate for affected employees.
Session timeout	30-minute idle / 8-hour absolute engineering baseline; configurable and subject to EGAS cybersecurity policy.	No.

Item	Current treatment / needed decision	Blocking?
Production backup/DR	Pilot minimal backup accepted; production values/restore testing defined with EGAS IT.	Production gate.
Server/reverse proxy/container standard	Application remains portable; Windows/Linux and IIS/Nginx/container policy remain IT deployment choices.	No for application design.
22-unit authority coverage	Admin must configure one active primary Approving Authority assignment for each active routing unit before pilot preflight passes. Current verified state is 0/22.	Pilot data/setup gate.
Active annual snapshot	No annual snapshot is active at v3.0 freeze; Phase 2B implements controlled import/activation.	Pilot data/setup gate.
Historical SAP/Fiori BRD wording	Written organizational re-confirmation of the standalone/Excel descope is recommended before formal UAT/production acceptance.	Governance/acceptance gate; not a coding blocker.

18. Traceability and references

18.1 High-level traceability

Source Requirement / Decision	SRS Coverage
BRD: two workflows, departmental routing	BR-001, Section 6
BRD: automatic employee data retrieval	FR-IMP/FR-EA via PostgreSQL annual snapshot
BRD: notifications between stages	FR-NOT-*
BRD: search/history	FR-SRCH-*
BRD: PDF and complete Audit Log	FR-PDF-*, FR-AUDPDF-*, SEC-006
Stakeholder: no SAP v1 / annual Excel	Scope 2.2, FR-IMP-*
Stakeholder: local accounts / admin	FR-AUTH-*
Stakeholder: confirmed workflow routes	Section 6
Stakeholder: rejection/return/restart semantics	BR-010..014, Section 6.3
Stakeholder: Organization claim queue	FR-ORG-01..03
Stakeholder: final form redesign + separate audit PDF	Section 8.3/8.4
Stakeholder: manual operational accounts + Deputy/Assistant routing configuration	FR-AUTH-14..16, FR-EA-14..16, FR-DEP-10..11, Data Section 7
Printable form: job-category subsection dropdown + manual fields	BR-021..022, FR-EA-16, FR-ORG-11..12

18.2 Original BRD technical requirement disposition

Original BRD technical item	v3.0 final disposition	Implementation status at freeze
Execute service completely on SAP Fiori platform	SUPERSEDED. Standalone internal React + TypeScript web application; no Fiori/UI5/BTP dependency.	Architecture migration complete; frontend implementation pending.
Direct connection to SAP HCM	SUPERSEDED. Controlled annual approved Excel snapshot imported to PostgreSQL; no live SAP integration.	Importer/activation is Phase 2B.
Automatic retrieval using Personnel Number	RETAINED against the active annual PostgreSQL snapshot, not SAP.	Employee lookup pending Phase 2B.
Multi-stage workflow across departments	RETAINED as separate Promotion and Secondment state machines with return/restart/cancel/audit behavior.	Workflow phases pending.

Original BRD technical item	v3.0 final disposition	Implementation status at freeze
Notifications on stage movement	RETAINED as in-app notifications; no email dependency required for v1.	Pending workflow implementation.
Search current and previous requests	RETAINED with role-scoped search/history and request/audit access.	Pending workflow/reporting implementation.
Print form as PDF	RETAINED: received-stage View as PDF, P1/S1 draft, P5/S5 final frozen PDF and separate audit PDF.	Pending documents phase.
Complete Audit Log	RETAINED as append-only/tamper-evident workflow/security evidence with printable reporting.	Security-event foundation exists; workflow audit/reporting pending.

18.3 Source and engineering reference legend

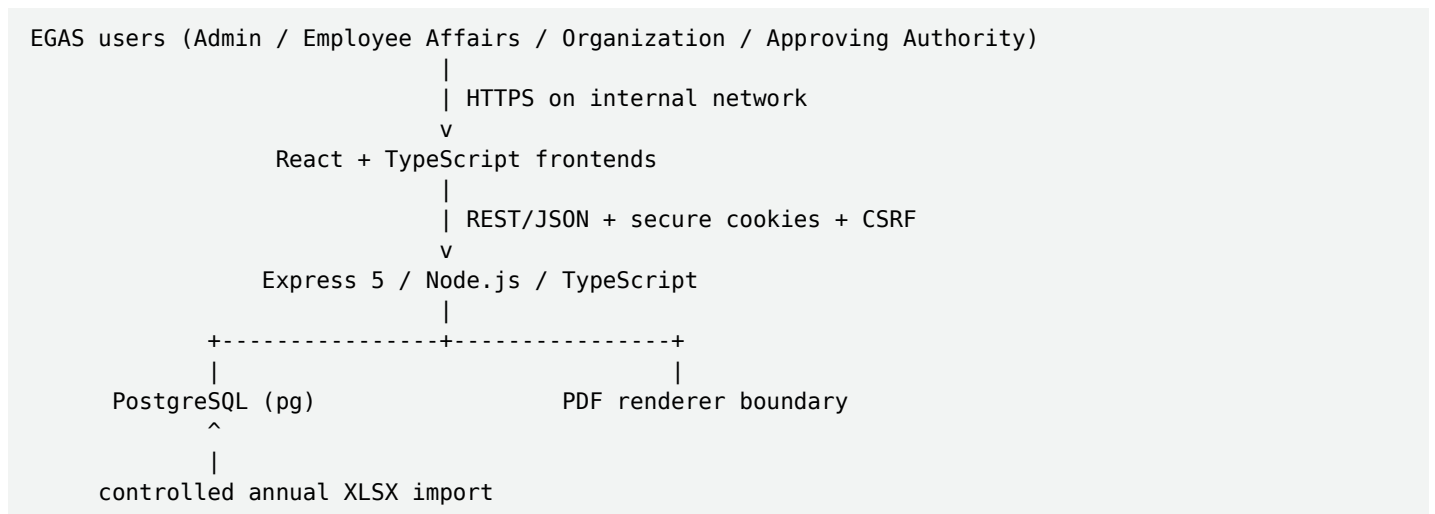
Ref	Document / standard	Use
S1	Business Requirement Document - Appraisal	Primary business source for workflow, roles, notifications, PDF and audit requirements.
S2	EGAS Missing Requirements Register Bilingual - stakeholder answers	Confirmed stakeholder decisions and technical/business clarifications.
S3	البيانات الأساسية annual workbook	Approved annual Arabic HR employee dataset for controlled PostgreSQL snapshot import.
S4	Final promotion/secondment printable forms	Reference form fields, grouping and official signoff presentation.
S6	النواب والمساعدین workbook	Reference-only staff workbook; not used to auto-create accounts or infer authorization.
S7	Stakeholder/IT follow-up decisions	Manual account/authority configuration and standalone/Excel architecture decisions.
S8	Approved Stitch/UI handoffs	Design-time visual/interaction reference using synthetic data only.
E1	Express 5 documentation	HTTP routing/middleware framework reference for the backend.
E2	node-postgres (pg) documentation	PostgreSQL pool, parameterized query and transaction reference.
E3	OWASP Password Storage / ASVS 5.0	Argon2id and application-security engineering verification baseline.
E4	W3C WCAG 2.2	Accessibility baseline; Level AA target.

19. System architecture specification

19.1 Architecture drivers and decisions

Driver	v3.0 architecture response
Standalone internal deployment	React applications and Express API run independently on EGAS-controlled infrastructure; no SAP/Fiori/BTP runtime requirement.
Small enterprise scale	Modular monolith rather than microservices; target comfortably supports ~1,500 employees and pilot load baseline.
Annual HR data supply	Controlled XLSX staging/validation/activation into immutable yearly snapshots.
Security-sensitive workflow	Server-side sessions, active-role authorization, transaction boundaries, least-privilege PostgreSQL runtime and append-only audit evidence.
Arabic-first UI	React + TypeScript with project-owned design system, RTL support and WCAG AA target; no UI5 dependency.
Maintainability	Explicit REST routes, TypeScript modules, pg repositories and versioned SQL migrations; avoid hidden framework-generated persistence endpoints.

19.2 System context



The browser never receives PostgreSQL credentials. Annual Excel is an operational input to the backend/import tooling, not a client-side database path. Historical SAP systems are outside the application trust/runtime boundary.

19.3 Logical architecture

Layer / module	Responsibility
React Workflow Portal	Employee Affairs, Organization and Approving Authority screens, role-aware navigation, forms, timelines, notifications and PDF actions.
React Admin Portal	Account/role management, routing/authority/delegation, annual import status, audit/reporting and system configuration.
Express API composition	HTTP lifecycle, routing, error handling, correlation IDs, health/readiness and middleware composition.
Auth module	AuthenticationProvider, Argon2id local auth, session lifecycle, CSRF, Origin checks, role selection and session rotation/revocation.
Admin/Authority modules	Explicit user/role/account, authority-assignment and delegation operations with optimistic concurrency and Manage-Admins protections.
Workflow module	Promotion/Secondment state machine, stage tasks/claims, iterations, return/restart/recall, signoffs and authorization policies.

Layer / module	Responsibility
Employee/import module	Annual XLSX inspection, header validation, staging, normalization, routing aliases, activation and employee lookup.
Audit/document modules	Append-only workflow/security evidence, notifications, stage-received/draft/final PDFs and audit reports.
Repository/DB layer	pg Pool, parameterized SQL repositories, explicit transactions, migration runner and PostgreSQL-specific integrity controls.

20. Frontend architecture

- Two React + TypeScript applications are planned: Workflow Portal and Admin Portal. They may share a common shell/component package but remain logically separate experiences.
- No SAP UI5, Fiori Elements or SAP BTP frontend dependency is part of the baseline.
- Approved Stitch screens and UI handoffs define visual hierarchy and interaction intent only; generated design code may be translated/refactored into the project React architecture.
- Frontend code never decides authorization. Hidden/disabled controls are UX only; the Express backend re-authorizes every protected operation.
- The browser stores no raw database credentials and no session token in localStorage/sessionStorage. Authentication is cookie-based.
- The preferred production topology is same-origin React + API (or approved reverse proxy), minimizing CORS complexity and matching the CSRF/Origin model.

21. Backend architecture - Node.js/Express

21.1 Service structure

```

/services/api
  /src
    app.ts / server.ts
  /config
  /db
    pool.ts / transaction.ts / migration-runner.ts
    /repositories /migrations /baseline
  /middleware
    authenticate / authorize / csrf / error-handler / request-context
  /modules
    auth / admin / authorities / audit / reference / health
    employee / import / workflow / documents    (as later phases are implemented)
/test

```

21.2 REST and mutation policy

- Use explicit REST endpoints and TypeScript request validation. Do not expose database tables as generic CRUD.
- Sensitive state transitions are explicit commands/routes with server-derived actor, role, request state and timestamps.
- All client-controlled SQL values use bound PostgreSQL parameters. Dynamic SQL identifiers are avoided or strict allow-listed.
- A central error handler maps validation/auth/authorization/conflict/rate-limit/unexpected errors to safe HTTP responses without SQL or stack-trace leakage.

21.3 Transaction policy

Operations that must be atomic acquire one pg client, execute BEGIN, perform all mutation and audit/security-evidence writes through that same client, then COMMIT or ROLLBACK and release. Pool-level query calls are not mixed into a transaction that requires one connection.

22. PostgreSQL data architecture and migrations

- PostgreSQL is the persistent system of record for application accounts, annual employee snapshots, workflow, audit, routing, authority assignments/delegations and document metadata.
- Normal runtime uses egas_app with CONNECT/USAGE and only required DML. It cannot create schemas/temp objects, create in public, or access historical CAP technical tables.
- Schema/migration ownership is separate from runtime. Runtime credentials are never used for DDL.

- The migration runner preserves egas_schemamigration, validates version/checksum, uses an advisory lock, executes full PostgreSQL scripts without naïve semicolon splitting, records only successful migrations and refuses changed already-applied scripts.
- Applied migration 001_postgres_integrity remains immutable. Existing table names are preserved; cleanup/renaming is not mixed with the architecture migration.

22.1 Data-model additions retained from v2.0

Entity/change	Purpose
user_account_role	Many-to-many role assignment; one account may hold multiple roles. Manage-Admins belongs to the Admin role assignment.
auth_session.active_role	Explicit selected role context for navigation, authorization and audit evidence.
routing_unit_source_alias	Explicit source-label mapping to approved routing units; no fuzzy inference.
import_batch header metadata	Record required-header validation/detected headers before staging/activation.
stage_task.claimed_role_snapshot	Preserve active role that claimed/owned the task.
stage_received_snapshot	Immutable JSON/hash/template snapshot for exactly the data an actor received and can View as PDF.
workflow_note	Append-only request/candidate messages with author role; candidate notes print chronologically in ملاحظات.
stage_action.actor_role_snapshot	Unambiguous action evidence for multi-role accounts.
workflow_signoff.signature_sha256_snapshot	Freeze the canonical signature hash used by the signoff.
pdf_generation_log RECEIVED state	Distinguish received-stage PDF, draft current form, final frozen form and audit PDF.

23. Annual Excel import architecture

- Input is an approved annual XLSX workbook provided through EGAS operational process. The application has no direct dependency on how that workbook was produced.
- Importer validates workbook/header structure before staging, matches by header name, preserves Arabic text, normalizes blanks/legacy "10", validates Personnel Number uniqueness and reports blocked/unmapped routing labels.
- Rows are staged first; activation is explicit and transactional. A failed validation/import does not replace the current active annual snapshot.
- Employee identity is stable across years while EmployeeAnnualSnapshot is immutable per year, preserving historical workflow evidence.
- Authority/staff reference workbooks are not application account provisioning sources.

24. Authentication, authorization and security architecture

24.1 Local authentication provider boundary

v1 uses local application authentication behind AuthenticationProvider. This provider boundary allows later replacement by an approved enterprise identity solution without changing workflow authorization semantics. No future provider is assumed or pre-integrated in v3.0.

24.2 Active-role authorization

An account may have multiple role assignments, but each authenticated session has exactly one active role. Middleware derives AuthContext from the server-side session and active assignment. Admin privileges do not authorize workflow actions when another role is active, and workflow roles do not inherit Admin privileges.

24.3 CSRF, Origin and cookie trust model

Mutating cookie-authenticated requests validate the CSRF cookie, X-CSRF-Token header, stored session CSRF hash and trusted Origin. CORS is disabled/restrictive by default. Production requires HTTPS and Secure session cookies.

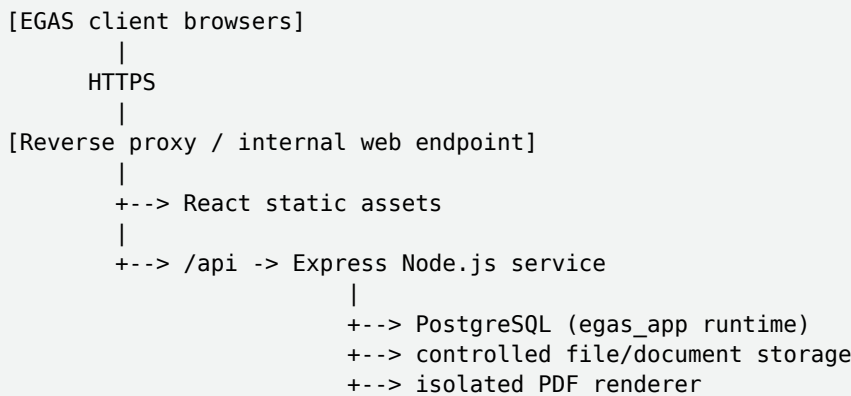
24.4 Database least privilege

The browser never connects to PostgreSQL. The Express API uses `egas_app` for normal runtime and is denied historical CAP technical tables. Database-owner/migration credentials are used only for controlled deployment operations.

25. Audit, notifications and document architecture

- Workflow audit events are append-only/tamper-evident and separate from operational application logs/security logs, though correlation IDs may link them.
- Security events capture authentication and privileged account/role/authority/delegation changes without storing passwords, raw session tokens or CSRF tokens.
- Notifications are in-app and do not replace audit evidence.
- Received-stage PDFs are immutable historical views; P1/S1 draft may evolve until submission; P5/S5 final PDF is frozen from the completed iteration.
- PDF rendering is a separate trust boundary with bounded concurrency, no arbitrary external/internal network egress, controlled local assets, encoded user text and no uncontrolled file:// access.

26. Deployment architecture



- Pilot may run on a controlled Windows development/demo machine; production OS/reverse proxy/container standard is chosen by EGAS IT.
- Configuration is supplied through machine-local/approved secret management; `.env.example` contains names/placeholders only.
- Application start must fail safely when required production configuration is missing.
- Server timestamps, audit timestamps and signoff timestamps use synchronized server time/NTP, not browser time.

27. Performance, reliability and future boundaries

27.1 Performance/reliability architecture

- Indexes support Personnel Number, workflow status/stage, routing-unit/period, assigned-user queues, request history and audit filters.
- Server-side pagination/filtering prevents unbounded history loads.
- Atomic stage transitions and Organization claims use database transactions/conditional updates.
- PDF generation failure is retryable and cannot alter workflow state.
- Completed snapshots remain readable across future annual imports.

27.2 Future change boundaries

Future change	Prepared boundary
Enterprise SSO/AD	Replace AuthenticationProvider while preserving local account/role mapping and active-role authorization semantics.
Different HR data source	Implement another EmployeeDataProvider/import adapter only if later approved; current v1 contract remains annual Excel snapshot.
Email notifications	Add NotificationChannel provider while in-app notification remains the system-of-record notification for v1.
VPN remote access	Network/deployment change only; application remains internal HTTPS.

Future change	Prepared boundary
More workflows	Add workflow definition/module while reusing Request/Iteration/Stage/Audit infrastructure.
English UI	Add translation resources and LTR layout; domain data remains Arabic-capable.

No pre-committed SAP future path

If EGAS later approves SAP integration, it is a new integration decision and must be designed/reviewed at that time. v3.0 does not reserve an SAP-specific runtime adapter or BTP/Fiori dependency.

28. Implementation structure and Architecture Decision Records

28.1 Suggested monorepo structure

```

/apps
  /workflow-web    React + TypeScript
  /admin-web       React + TypeScript
/services
  /api             Express 5 + TypeScript + pg backend
/packages
  /shared-types
  /ui              shared EGAS UI components/tokens
/docs
  /requirements
  /handoff
/design/stitch     approved synthetic UI references
/scripts           setup/import/backup/restore/pilot helpers as needed

```

28.2 Architecture Decision Records

ADR	Decision	Reason
ADR-001	Modular monolith, not microservices	Tightly coupled workflow, modest enterprise scale and simplest internal operations.
ADR-002	React + TypeScript with EGAS design system	Standalone Arabic RTL UI; no SAP UI runtime dependency; approved designs can be implemented with standard React components.
ADR-003	Node.js + TypeScript + Express 5 backend	Direct, widely understood REST/middleware architecture with explicit business/service/repository boundaries.
ADR-004	pg / parameterized SQL for PostgreSQL	Simple explicit database access, strong transaction control and preservation of PostgreSQL-specific integrity logic without an ORM.
ADR-005	Two SPAs: Workflow + Admin	Separate Admin UX while sharing core design/components and avoiding multiple role-specific deployments.
ADR-006	PostgreSQL identity + immutable annual snapshots	Annual refresh does not rewrite historical workflow decisions.
ADR-007	Local authentication v1 with provider boundary	No AD/SSO now; future replacement remains possible without changing authorization model.
ADR-008	Iteration-based workflow history	Return/restart begins at start without deleting prior approvals/actions.
ADR-009	Append-only tamper-evident audit	Meets complete/immutable audit requirement and protects long-term history.

ADR	Decision	Reason
ADR-010	PDF generated on demand from frozen data	Corrections before final approval remain possible while completed output stays stable.
ADR-011	Controlled annual import through staging	Protects workflow from malformed Excel and makes annual operations repeatable.
ADR-012	Versioned SQL migrations are schema authority	After CAP removal there is one physical PostgreSQL migration history; no competing CDS schema authority.
ADR-013	No active SAP technology association	IT confirmed standalone operation and annual Excel data supply; SAP/Fiori/HCM remain historical traceability only.

29. Repository, Codex and pilot handoff contract

Repository item	Required content
AGENTS.md	Persistent developer/Codex guardrails, source precedence, security rules and do-not-invent-business-rules instruction.
README.md	Developer overview and normal setup/build/test entry points.
PILOT_SETUP.md	Windows PC/laptop pilot runbook including PostgreSQL setup/restore/import and local start procedure.
.env.example	Configuration variable names/placeholders only; never real passwords/secrets.
docs/requirements	This v3.0 baseline and supporting authoritative requirements artifacts.
design/stitch	Approved synthetic screens/exports and design rules; design-time only.
services/api	Express backend, auth/admin, future workflow/import/audit/PDF logic, PostgreSQL repositories/migrations and tests.
apps/workflow-web + apps/admin-web	React + TypeScript frontend implementations when built.
tests	Synthetic unit/integration/e2e fixtures and security tests.

29.1 Stable developer/pilot command interface

Command	Purpose
npm install	Install repository dependencies.
npm run build	Build the Express/TypeScript backend and later frontend workspaces.
npm test	Run automated unit/integration/security regression tests.
npm run typecheck	TypeScript static verification.
npm run security:check	Secret/dependency/security regression gate.
npm run db:migrate	Apply versioned PostgreSQL migrations using deployment credentials.
npm run admin:bootstrap	Create first privileged Admin only when no privileged Admin exists.
npm run pilot:check	Validate environment, runtime role, routing units, privileged Admin, authority coverage and active annual snapshot.
npm run dev	Run the local Express backend (and, once implemented, coordinated frontend dev commands).
npm start	Run production-intended built service.

30. Final implementation handoff and next phase

At the v3.0 freeze, the active backend architecture is fully migrated to Express + pg and Phase 2A is complete. No Phase 2B data import/employee lookup, workflow execution, signature/PDF generation or production React screens are claimed complete by this document unless separately evidenced in the repository.

Next authorized implementation scope

Phase 2B - Annual Employee Data & Routing: XLSX staging/validation/activation, routing aliases, employee identity/annual snapshots and employee lookup. Do not bypass the controlled import rules or fabricate unresolved routing mappings.

This document is the clean consolidated requirements/architecture baseline for subsequent Codex prompts, implementation reviews, UI handoffs and stakeholder acceptance work.